

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalization, and targeted advertising. [Privacy Policy](#).

Accept

Deny Non-Essential

Manage Preferences

An attacker modifies the parameters of the SOAP message that is sent from the service consumer to the service provider to initiate a SQL injection attack. On the service provider side, the SOAP message is parsed and parameters are not properly validated before being used to access a database in a way that does not use parameter binding, thus enabling the attacker to control the structure of the executed SQL query. This pattern describes a SQL injection attack with the delivery mechanism being a SOAP message.

▼ **Likelihood Of Attack**

High

▼ **Typical Severity**

Very High

▼ **Relationships**

	Nature	Type	ID	Name
	ChildOf		66	SQL Injection
	CanFollow		279	SOAP Manipulation
	CanPrecede		108	Command Line Execution through SQL Injection

	View Name	Top Level Categories
	Domains of Attack	Software
	Mechanisms of Attack	Inject Unexpected Items

▼ **Execution Flow**

Explore

Detect Incorrect SOAP Parameter Handling: The attacker tampers with the SOAP message parameters and looks for indications that the tampering caused a change in behavior of the targeted application.

Techniques

The attacker tampers with the SOAP message parameters by injecting some special characters such as single quotes, double quotes, semi columns, etc. The attacker observes system behavior.

Experiment

Probe for SQL Injection vulnerability: The attacker injects SQL syntax into vulnerable SOAP parameters identified during the Explore phase to search for unfiltered execution of the SQL syntax in a query.

Exploit

Inject SQL via SOAP Parameters: The attacker injects SQL via SOAP parameters identified as vulnerable during Explore phase to launch a first or second order SQL injection attack.

Techniques

SOAP parameters are not properly validated at the service provider

The service provider does not properly utilize parameter binding when building SQL queries

▼ Skills Required

[Level: Medium]

If the attacker is able to gain good understanding of the system's database schema

[Level: High]

If the attacker has to perform Blind SQL Injection

▼ Resources Required

None: No specialized resources are required to execute this type of attack.

▼ Consequences



Scope	Impact	Likelihood
Integrity	Modify Data	
Availability	Unreliable Execution	
Confidentiality	Read Data	
Confidentiality Access Control Authorization	Gain Privileges	
Confidentiality Integrity Availability	Execute Unauthorized Commands	

▼ Mitigations

Properly validate and sanitize/reject user input at the service provider.

Ensure that prepared statements or other mechanism that enables parameter binding is used when accessing the database in a way that would prevent the attackers' supplied data from controlling the structure of the executed query.

At the database level, ensure that the database user used by the application in a particular context has the minimum needed privileges to the database that are needed to perform the operation. When possible, run queries against pre-generated views rather than the tables directly.

▼ Example Instances

An attacker uses a travel booking system that leverages SOAP communication between the client and the travel booking service. An attacker begins to tamper with the outgoing SOAP messages by modifying their parameters to include characters that would break a dynamically constructed SQL query. They notice that the system fails to respond when these malicious inputs are injected in certain parameters transferred in a SOAP message. The attacker crafts a SQL query that modifies their payment amount in the travel system's database and passes it as one of the

20	Improper Input Validation
----	---------------------------

► **Content History**

Page Last Updated or Reviewed: July 31, 2018